

Cyber Laws & Regulations



Nancy LaTourrette, CISSP
Computer Science & Engineering

Security & Privacy Controls

NIST Special Publication 800-53 provides security and privacy controls and a process for selecting controls to protect organizational assets, individuals, and the Nation from hostile cyber attacks, natural disasters, structural failures, and human errors. The controls are customizable and implemented as part of an organization-wide process.

- (NIST) Security and Privacy Controls for Federal Information Systems and Organizations, Revision 4, 2013

Computer Security Act

*The Computer Security Act (1987¹) directed NIST² to establish a **computer standards program** for federal computer systems, including **guidelines for security**.*

- Use **security guidelines developed by the NSA³** regarding protecting sensitive information. *↳ limited to technical assistance*
- Develop standards of **minimum acceptable practices**.
↳ for maintaining CIA of sensitive federal information
- Establishment of **security policies** for federal computer systems that contain sensitive information.
↳ e.g. inventory, risk assessment, contingency plans, documentation, security testing/audits
- Mandatory **security awareness training** for federal employees that use those systems.
↳ role-based training of security policies, legal expectations, and refresher material

FISMA

The Federal Information Security Management Act (FISMA) requires federal agencies to develop, document, and implement an information security and protection program.

- **Reduces the security risk** to federal data and manages **federal spending** on information security.
↳ assessments, plans, security controls, monitoring
- Includes information security programs provided or managed by **another agency, contractor, or other sources**.
↳ requires agencies to include 3rd parties in the above activities
- **Risk-based policy** for cost-effective security.
↳ policy/resource decisions are based on likelihood of threat, proportional to cost-effectiveness
- Conduct **annual review** of the agency's information security program.
- **Expanded to include state agencies** administering federal programs like Medicare. Furthermore, states operate federally-connected systems

FISMA

Top FISMA requirements:

- *Information Security Inventory* – keep an inventory of all information systems used.
- *Risk Categorization* – categorize information in order or risk (most sensitive).
- *Security Plan* – create and maintain a security plan.
- *Security Controls* – implement NIST 800-53 security controls into security plan.
- *Risk Assessments* – conduct a three-tiered¹ risk assessment.
- *Security Reviews* – conduct an annual security review.

NIST 800-53

NIST Special Publication 800-53 Revision 4:

Step 1: **Categorize** the information system based on impact assessment.

Step 2: **Select** the applicable security control baseline based on security categorization.

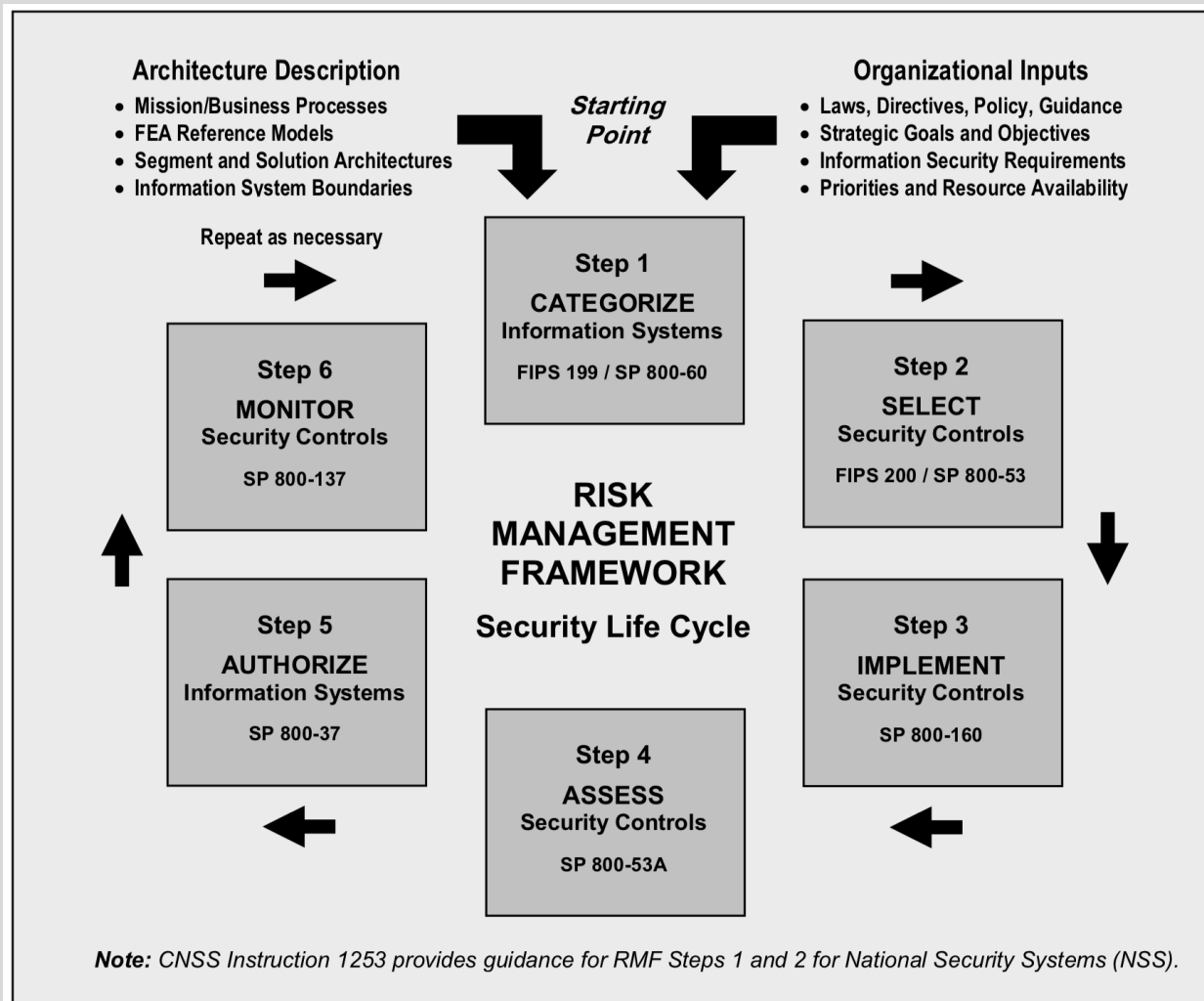
Step 3: **Implement** the security controls **and document** the design, development, and implementation.

Step 4: **Assess** the security controls to determine extent to which the controls are producing the desired outcome.

Step 5: **Authorize** information system operation based on a determination of risk.

Step 6: **Monitor** the security controls on an ongoing basis to determine effectiveness.

NIST 800-53



Common Criteria

The Common Criteria for Information Technology and Security evaluation are ISO standards specifying security requirements and evaluation criteria.

Rainbow Series (1980s-1990s) – is a **library of documents about computer security**. Topics range from password management to configuration management and audits to covert channels.

Common Criteria (late 1990s) – goal is to provide increased confidence in information security. Based on Orange Book¹ but more **flexible and adaptable** as information technology evolved.

Formal Actions – taken during **developing, evaluating and operating** process.

Requirements – a common set of security requirements for use in evaluation of systems. **Functional and Assurance requirements** define the desired security behavior and are effective and implemented correctly.

USA Patriot Act

The USA Patriot Act was signed into law in 2001 as a response to the 9/11 attacks to improve the ability of law enforcement to detect and deter terrorism.

- Updated laws to reflect technological advancements.
- Expanded powers of information gathering¹.
- Sunset Provisions specific to cyber:
 - *Section 209* – seize voice mail with search warrant vs. surveillance order.
 - *Section 217* – treats cyber hackers same as physical intruders.
 - *Section 220* – search warrant obtained for ISP outside jurisdiction of courts.

Federal Cyber Protection Laws

- *Americans with Disabilities Act (Section 508)* – requires federal agencies to make all **public-facing content accessible**. Updated to include non public-facing content such as emergency notifications.
- *FDA 21 CFR 806* – requires **reporting of changes in medical devices** to FDA. Reduced reporting requirements for cybersecurity routine updates, patches and device enhancements with certain provisos¹.
- *Cybersecurity Information Sharing Act (CISA)* - allows the **sharing of internet traffic information** between the U.S. government and technology and manufacturing companies.

International Data Privacy

Organization for Economic Co-Operation and Development (OECD) promotes policies that will improve the economic and social well-being of people around the world.

OECD's guidelines governing the **protection of privacy and transborder flow of personal data**:

- Limit the collection of personal data
- Collection should be relevant to use
- Specify purposes for collection
- Limit data disclosure to purpose specified
- Protected by reasonable safeguards
- Transparent practices and policies
- Individual rights to obtain personal data
- Data controller responsible for compliance

EU Laws & Regulations

GLDR: GDPR forces multinational companies to respect user-privacy, even for non-EU customers.
EU Data Protection Directive protects the fundamental rights and freedoms of natural persons, and in particular their *right to privacy with respect to the processing of personal data*.

EU-U.S. Privacy Shield protects the fundamental rights of anyone in the *EU whose personal data is transferred to the United States* as well as bringing legal clarity for businesses relying on transatlantic data transfers.

EU General Data Protection Regulation (GDPR) updates the data protection framework to increase individual's control over their data; unify rules and enforcement throughout the EU; *ensure data protection in a globalized world*; and extend the framework to include data use by police and criminal justice operations.

Data Breach Laws

Data Breach Laws may be dependent on industry, data category, number of records exposed or time since breach. There are national and state laws with several new state data breach laws taking effect in 2020.

General Data Protection Regulation (GDPR) - notification to the supervisory authority is made **within 72 hours** or shall be accompanied by reasons for the delay.

California Consumer Privacy Act (CCPA) - **consumers can sue** when unencrypted or nonredacted data exposed as a result of failure to implement and maintain reasonable security procedures. *One of many state-level consumer digital privacy laws.*

Federal Exchange Data Breach Notification Act of 2015 – requires a **health insurance exchange** to notify customers of a cyber breach no later than 60 days.

Cybercrime Laws

"Computer crime laws encompass a variety of actions that destroy or interfere with normal operation of a computer system. All 50 states have computer crime laws; most address unauthorized access or computer trespass. Some state laws also directly address other specific types of computer crime, such as spyware, phishing, denial of service attacks, and ransomware."

-- Computer Crime Statutes, National Conference of State Legislatures, June 2018

Computer Fraud and Abuse Act

Computer Fraud and Abuse Act (CFAA) - This law has been amended and expanded as internet technology has advanced, and it continues to form the basis for federal prosecutions of computer-related criminal activities.

Offense	Section	Sentence*
Obtaining National Security Information	(a)(1)	10 (20) years
Accessing a Computer and Obtaining Information	(a)(2)	1 or 5 (10)
Trespassing in a Government Computer	(a)(3)	1 (10)
Accessing a Computer to Defraud & Obtain Value	(a)(4)	5 (10)
Intentionally Damaging by Knowing Transmission	(a)(5)(A)	1 or 10 (20)
Recklessly Damaging by Intentional Access	(a)(5)(B)	1 or 5 (20)
Negligently Causing Damage & Loss by Intentional Access	(a)(5)(C)	1 (10)
Trafficking in Passwords	(a)(6)	1 (10)
Extortion Involving Computers	(a)(7)	5 (10)

* The maximum prison sentences for second convictions are noted in parentheses.

overrides state/local laws

Federal Cybercrime Laws

[Electronic Communications Privacy Act \(ECPA\)](#) - updated the Federal Wiretap Act of 1968 to apply to **interception of computer and other digital and electronic communications**.

[Stored Communications Act \(SCA\)](#) - Title II of ECPA, regarding **email privacy** and ISP voluntary and mandatory disclosure.

[Identity Theft Enforcement and Restitution Act of 2008 \(ITERA\)](#) - lowers damage amount needed to prosecute; **expands definition of cyber-extortion**.

[Child Pornography Prevention Act](#) - revises the definition of "visual depiction" to include **data stored on computer disk** or by electronic means. *If discovered during your organizational/state investigation, it must be given to federal.*

[Cyber Security Enhancement Act \(CSEA\)](#) - amends sentencing guidelines for some computer crimes. **Allows an ISP to disclose customer data** to government agencies if deemed an emergency.

International Treaties & Agreements

G8 Communique (1997) – G8 countries adopted **10 principles** to combat “high tech” crime.

Convention on Cybercrime (2001) – known as the **Budapest Convention**, addressed the **jurisdictional issues** and disjoint cybercrime laws due to rise of the internet.

Additional Protocol to the Convention on Cybercrime (2003) – obligation to enact laws to **criminalize racist or xenophobic acts that are expressed or otherwise communicated online**.

Joint Cybercrime Action Taskforce (J-cat) – facilitating the joint identification, prioritization, preparation and initiation of **cross-border investigations and operations** against cybercrime threats.

References

[1] H.R.145 - COMPUTER SECURITY ACT OF 1987

<https://www.congress.gov/bill/100th-congress/house-bill/145>

[2] NSA/NCSC RAINBOW SERIES

<https://fas.org/irp/nsa/rainbow.htm>

[3] FEDERAL INFORMATION SECURITY MANAGEMENT ACT (FISMA)
IMPLEMENTATION PROJECT

<https://www.nist.gov/programs-projects/federal-information-security-management-act-fisma-implementation-project>

[4] DEFINITION OF FISMA COMPLIANCE

<https://digitalguardian.com/blog/what-fisma-compliance-fisma-definition-requirements-penalties-and-more>

[5] SUBCOMMITTEE ON CRIME, TERRORISM, AND HOMELAND SECURITY, STEVEN M. MARTINEZ DEPUTY ASSISTANT DIRECTOR, CYBER DIVISION, FBI, APRIL 2005

<https://archives.fbi.gov/archives/news/testimony/computer-provisions-of-the-usa-patriot-act>

References (cont'd)

[6] GOVERNMENT COLLECTION OF PRIVATE INFORMATION: BACKGROUND AND ISSUES RELATED TO THE USA PATRIOT ACT REAUTHORIZATION IN BRIEF, CRS

<https://fas.org/sgp/crs/intel/R44042.pdf>

[7] SECURITY AND PRIVACY CONTROLS FOR FEDERAL INFORMATION SYSTEMS AND ORGANIZATIONS, NIST 800-53 REVISION 4

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>

[8] EUROPEAN UNION DATA PROTECTION DIRECTIVE, <http://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex:31995L0046>

[9] OECD, GUIDELINES ON THE PROTECTION OF PRIVACY AND TRANSBORDER FLOWS OF PERSONAL DATA,

<http://www.oecd.org/sti/ieconomy/oecdguidelinesontheprivacyandtransborderflowsofpersonaldata.htm>

[10] CCPA AND GDPR COMPARISON CHART, PRACTICAL LAW, L.JEHL A. FRIEL, BAKERHOSTETLER LLP

<https://www.bakerlaw.com/webfiles/Privacy/2018/Articles/CCPA-GDPR-Chart.pdf>

References (cont'd)

- [11] COMPUTER CRIME STATUTES, NATIONAL CONFERENCE OF STATE LEGISLATURES, JUNE 2018
<http://www.ncsl.org/research/telecommunications-and-information-technology/computer-hacking-and-unauthorized-access-laws.aspx>
- [12] INTERNATIONAL CYBERCRIME TREATY: LOOKING BEYOND RATIFICATION, DANIEL ROBEL, SANS INSTITUTE, 2006
<https://www.sans.org/reading-room/whitepapers/incident/paper/1756>
- [13] PROSECUTING COMPUTER CRIMES, COMPUTER CRIME AND INTELLECTUAL PROPERTY SECTION CRIMINAL DIVISION, DOJ
<https://www.justice.gov/sites/default/files/criminal-ccips/legacy/2015/01/14/ccmanual.pdf>
- [14] MEETING OF JUSTICE AND INTERIOR MINISTERS OF THE EIGHT, COMMUNIQUE, 1997
<https://www.justice.gov/sites/default/files/ag/legacy/2004/06/08/97Communique.pdf>
- [15] THE COUNCIL OF EUROPE'S CONVENTION ON CYBERCRIME, A. WEBER
<http://scholarship.law.berkeley.edu/cgi/viewcontent.cgi?article=1416&context=btlj>